

Ghulam Ishaq Khan Institute of Engineering Sciences and Technology



Project: Secure QR-Based Attendance System

Course: Secure Software Design (CY-321)

Security Requirements and Planning Document

Group Members

Zulqarnain Umar	2023556
Awais Khan	2023139
Moawiz-Ur-Rehman	2023278

1. Introduction

This document defines the security requirements and implementation planning for the Secure QR-Based Attendance Management System. The system enables teachers to generate time-limited QR codes for attendance sessions and students to scan these codes to mark attendance. All validation occurs server-side with strict nonce reuse prevention, enrollment verification, and time window compliance.

1.1 Document Purpose

- Define functional and non-functional security requirements
- Provide implementation guidelines for development teams
- Define acceptance criteria for security testing

2. Security Requirements

2.1 Authentication Requirements

ID	Requirement	Priority	Component
AUTH-01	Multi-factor authentication for teacher accounts	Critical	Authentication Service
AUTH-02	JWT-based authentication with 8-hour absolute expiry and 30-minute inactivity timeout	Critical	Authentication Service
AUTH-03	Role-based access control (Teacher/Student) on every request	High	Backend Server
AUTH-04	Secure logout and token revocation mechanism	High	Authentication Service
AUTH-05	Account lockout after 5 failed attempts (15-minute lockout)	Medium	Authentication Service

ID	Requirement	Priority	Component
AUTH-06	University SSO integration for credential validation	Critical	Authentication Service
AUTH-07	Secure session management with HTTP-only cookies	High	Backend Server
AUTH-08	SAML assertions must be validated for replay protection	Critical	Authentication Service

2.2 QR Token Generation Requirements

ID	Requirement	Priority	Component
QR-01	QR codes must contain: Session ID, Course ID, timestamp, and cryptographically secure random nonce (32+ bytes)	Critical	QR Token Generator
QR-02	QR token validity period: maximum 60 seconds	Critical	QR Token Generator
QR-03	Each QR code must be single-use; nonce tracked in Redis with appropriate TTL	Critical	QR Token Generator + Redis
QR-04	QR data must be cryptographically signed to prevent tampering	Critical	QR Token Generator
QR-05	QR codes cannot be downloaded or saved by teachers	Medium	Teacher Web Client

2.3 Attendance Verification Requirements

ID	Requirement	Priority	Component
AV-01	Verify student enrollment in the course before marking attendance	Critical	Attendance Verification
AV-02	Check token expiration against server time (NTP-synchronized)	Critical	Attendance Verification
AV-03	Prevent nonce reuse via Redis storage	Critical	Attendance Verification + Redis
AV-04	Detect and block duplicate attendance submissions	High	Attendance Verification
AV-05	Validate time window compliance (± 30 seconds drift tolerance)	High	Attendance Verification
AV-06	Lock attendance records when teacher closes session	Medium	Attendance Verification

2.4 API Security Requirements

ID	Requirement	Priority	Component
API-01	All API endpoints must validate JWT tokens on every request	Critical	Backend Server
API-02	Input sanitization and validation for all parameters	Critical	Backend Server
API-03	Rate limiting per student (max 5 attempts per minute)	High	Backend Server

ID	Requirement	Priority	Component
API-04	Parameterized queries to prevent SQL injection	Critical	Backend Server
API-05	Proper error handling (no stack traces to client)	Medium	Backend Server
API-06	Multi-step validation for attendance marking transactions	High	Backend Server

2.5 Cryptography Requirements

ID	Requirement	Priority	Component
CRYPTO-01	All communications must use TLS 1.3	Critical	All components
CRYPTO-02	Passwords must be hashed with bcrypt/Argon2	Critical	Authentication Service
CRYPTO-03	JWT signing keys stored in HSM or secure environment variables	Critical	Authentication Service
CRYPTO-04	Data at rest encryption for PII in PostgreSQL	High	PostgreSQL
CRYPTO-05	Regular key rotation (signing keys every 90 days)	Medium	Authentication Service

2.6 Database Security Requirements

ID	Requirement	Priority	Component
DB-01	Principle of least privilege for database service accounts	Critical	PostgreSQL
DB-02	Network isolation (database not publicly accessible)	Critical	PostgreSQL
DB-03	Encrypted backups with access controls	High	PostgreSQL
DB-04	Comprehensive audit logging of all database activities	High	PostgreSQL
DB-05	Regular security patching (monthly)	High	PostgreSQL
DB-06	Row-level security for multi-tenant data isolation	Medium	PostgreSQL

2.7 Availability Requirements

ID	Requirement	Target	Component
AVAIL-01	System uptime during class hours (8 AM - 5 PM)	99.5%	All components
AVAIL-02	Rate limiting to prevent DoS attacks	Implemented	Backend Server + Redis
AVAIL-03	Automatic failover for critical components	Documented	Infrastructure

ID	Requirement	Target	Component
AVAIL-04	Graceful degradation (manual attendance fallback)	Documented	Teacher Web Client

2.8 Logging and Monitoring Requirements

ID	Requirement	Retention	Component
LOG-01	Log all authentication attempts (success/failure)	90 days	Authentication Service
LOG-02	Log all attendance marking events	1 year	Backend Server
LOG-03	Log all session creation and closure events	1 year	Backend Server
LOG-04	Centralized log aggregation	90 days	Monitoring System
LOG-05	Real-time alerts for suspicious activities	Immediate	SIEM

2.9 Client-Side Requirements

ID	Requirement	Priority	Component
CLIENT-S-01	No sensitive data stored locally on student devices	Critical	Student Client

ID	Requirement	Priority	Component
CLIENT-S-02	JWT tokens stored securely (HTTP-only cookies)	Critical	Student Client
CLIENT-S-03	Regular app updates with vulnerability scanning	Required	Student Client
CLIENT-T-01	Implement frame-busting techniques to prevent clickjacking	Required	Teacher Client
CLIENT-T-02	Content Security Policy (CSP) configured to mitigate XSS	Required	Teacher Client
CLIENT-T-03	JavaScript sandboxing for untrusted scripts	Required	Teacher Client
CLIENT-T-04	HTTPS enforcement with HSTS	Implemented	Teacher Client

3. Implementation Planning

3.1 Development Phases

Phase	Duration	Key Deliverables	Security Activities
Phase 1: Foundation	Week 1-2	Project setup, database schema, authentication service	Threat modeling, security requirements finalization
Phase 2: Core Features	Week 3-4	QR generation, attendance verification, basic API	Secure code reviews, SAST scanning

Phase	Duration	Key Deliverables	Security Activities
Phase 3: Integration	Week 5-6	SSO integration, client implementations	Integration testing, security unit tests
Phase 4: Testing	Week 7-8	Full system testing, penetration testing	DAST scanning, replay attack tests, load testing
Phase 5: Deployment	Week 9-10	Production deployment, documentation	Security hardening, monitoring setup

3.2 Security Testing Schedule

Test Type	Tool/Method	Frequency	Responsible
SAST (Static Analysis)	SonarQube, Bandit	Every commit	Developers
DAST (Dynamic Analysis)	OWASP ZAP, Burp Suite	Weekly	Security Lead
Dependency Scanning	OWASP Dependency Check	Weekly	Developers
Penetration Testing	Manual testing	Pre-release	Security Team
Replay Attack Testing	Custom test scripts	Per sprint	QA Team
Load Testing	JMeter	Pre-release	DevOps

4. Acceptance Criteria

The system will be considered secure and ready for deployment when:

1. All Critical and High priority requirements are implemented and verified
2. No Critical or High severity vulnerabilities remain from penetration testing
3. Replay attack tests confirm once reuse is impossible
4. SQL injection attempts are all blocked
5. Authentication bypass attempts fail consistently
6. QR tokens expire within 60 seconds and cannot be reused
7. Audit logging captures all security-relevant events
8. Current risk rating remains below 20%

5. Risk Summary

Risk ID	Risk Description	Requirements
R01	QR replay attacks	QR-02, QR-03, AV-03
R02	Authentication bypass	AUTH-01, AUTH-02, AUTH-06
R03	Token manipulation	QR-04, AV-02
R04	Database breach	DB-01 through DB-06
R05	Server downtime	AVAIL-01 through AVAIL-04
R06	Session hijacking	AUTH-02, AUTH-04
R10	Brute force attacks	AUTH-05, API-03
R11	MITM attacks	CRYPTO-01, CLIENT-T-04